



Universidad Mariano Gálvez de Guatemala
Sede El Naranjo
Facultad de Ingeniería en Sistemas de Información
Ingeniería en Ciencias y Sistemas
Seguridad y Auditoría de Sistemas

ANEXO AL PROYECTO DE CURSO

Aplicación del Modelo del Triángulo de la Ciberresiliencia a la Plataforma de Comercio Electrónico MarketGT

*Evaluación del equilibrio entre protección, detección y respuesta en la propuesta de implementación de un Web Application
Firewall bajo la norma ISO/IEC 27001*

Integrantes

Diego Antonio Beteta García — 9490-22-12878
Jonathan Rogelio Herrera Soto — 9490-22-11551
Mario Roberto Rompich Yoc — 9490-17-1752

Guatemala, 8 de septiembre de 2026

1. El Modelo del Triángulo de la Ciberresiliencia

El modelo parte de una premisa que reordena las prioridades del diseño defensivo: la prevención pura fallará eventualmente, sea por la aparición de vulnerabilidades de día cero o por el error humano. Bajo ese supuesto, la supervivencia operativa del negocio no depende de la robustez de un único control, sino de mantener equilibradas las tres aristas del triángulo, que son la protección, la detección y la respuesta.

La consecuencia práctica de este planteamiento es que una organización que concentra toda su inversión en un solo vértice no obtiene más seguridad, sino que desplaza el riesgo hacia los vértices desatendidos. Una plataforma con controles preventivos de alta madurez, pero sin capacidad de detectar una intrusión ni de contenerla, no evita el compromiso: únicamente tarda más en enterarse de que ocurrió y más todavía en recuperarse.

Definición de los Tres Vértices

- **Protección.** Mantener actualizados los cortafuegos y los servidores, gestionar los parches de software y formar continuamente al personal humano.
- **Detección.** Asegurar que las herramientas de monitoreo (EDR y SIEM) estén perfectamente configuradas y monitorizadas de forma activa por personal experto.
- **Respuesta.** Contar con procedimientos claros y ensayados para aislar los equipos comprometidos y restaurar las operaciones en minutos, no en semanas.

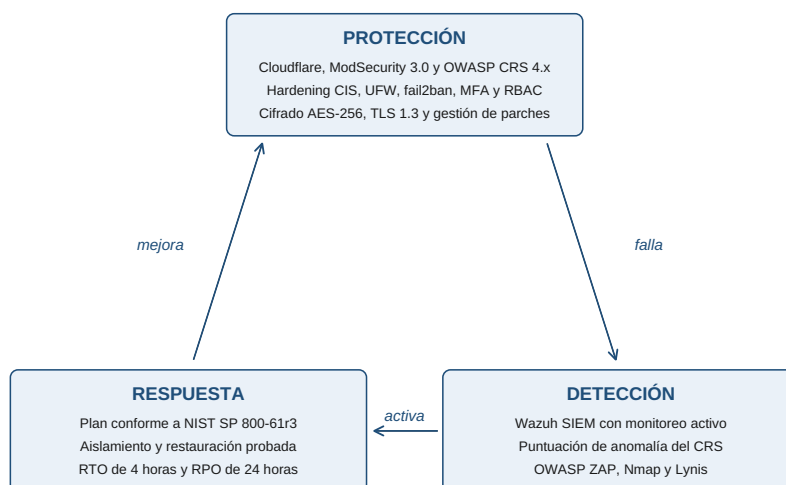
El tercer vértice es el que introduce la exigencia más estricta del modelo, porque no se satisface con documentación: exige que los procedimientos hayan sido *ensayados*. Un plan de respuesta que nunca se ha probado tiene el mismo valor operativo que no tener plan alguno.

2. Aplicación del Modelo a la Plataforma MarketGT

El proyecto propone una arquitectura de defensa en profundidad de seis capas para una plataforma de comercio electrónico bajo modelo SaaS, protegida mediante un Web Application Firewall. La Figura 1 traslada esa arquitectura a los tres vértices del modelo, ubicando en cada uno los componentes concretos que le corresponden y el ciclo que los vincula.

Figura 1

Triángulo de la ciberresiliencia aplicado a la plataforma MarketGT



Nota. Las flechas representan el ciclo del modelo: la protección falla eventualmente, la detección advierte el fallo y activa la respuesta, y la respuesta retroalimenta la protección mediante la corrección de la causa raíz. El vértice de respuesta contiene los componentes que aún no forman parte del documento vigente del proyecto.

2.1 Vértice de Protección

El proyecto concentra en este vértice la mayor parte de sus controles. Las seis capas del esquema de defensa en profundidad son, en su totalidad, controles preventivos: mitigación de denegación de servicio y WAF de borde en Cloudflare, restricción de puertos con UFW y bloqueo de fuerza bruta con fail2ban, endurecimiento del sistema operativo conforme al CIS Benchmark, inspección de capa 7 con ModSecurity y el OWASP Core Rule Set, autenticación multifactor y control de acceso por roles en Laravel, y cifrado AES-256 con tokenización en MariaDB. Es, sin discusión, el vértice de mayor madurez de la propuesta.

No obstante, la definición del modelo incorpora un componente que el documento vigente no contempla: la formación continua del personal humano. Esa omisión corresponde al control 6.3 del Anexo A de la norma ISO/IEC 27001:2022 y resulta relevante porque el propio modelo identifica el error humano como una de las dos causas por las que la prevención termina fallando. Igualmente, el documento describe la gestión de parches sin fijar un acuerdo de nivel de servicio que establezca en cuántas horas debe corregirse una vulnerabilidad crítica publicada.

2.2 Vértice de Detección

El proyecto despliega Wazuh como sistema de gestión de eventos e información de seguridad, complementado con la puntuación de anomalía acumulada del Core Rule Set, el escaneo de vulnerabilidades con OWASP ZAP, el descubrimiento de puertos con Nmap y la auditoría de endurecimiento con Lynis. El instrumental es adecuado y suficiente para el alcance del proyecto.

La brecha no reside en las herramientas sino en su operación. El modelo exige que las herramientas estén «monitorizadas activamente por expertos», y el documento no especifica quién revisa las alertas, en qué horario lo hace, bajo qué casos de uso se generan, ni cuál es la política de retención de los registros. Tampoco se establece que los registros de Cloudflare y de la aplicación Laravel se integren al SIEM, con lo que dos de las seis capas quedarían fuera de la correlación. Una herramienta desplegada sin operación asociada produce evidencia para la auditoría, pero no capacidad real de detección.

2.3 Vértice de Respuesta

Es el vértice ausente de la propuesta. El documento cita la norma NIST SP 800-61r3 en su tabla de estándares aplicados y menciona la fase de responder dentro del ciclo SKiP, pero ninguno de los siete entregables del cronograma corresponde a un plan de respuesta a incidentes. No se definen procedimientos operativos, matriz de escalamiento, objetivos de recuperación, pruebas de restauración ni plan de comunicación ante una brecha de datos.

Esta ausencia produce una inconsistencia verificable dentro del propio documento. El primer objetivo del modelo de negocio compromete una disponibilidad del servicio del 99.9 %, equivalente a un máximo aproximado de 43 minutos de indisponibilidad mensual, mientras que la tabla de plataforma tecnológica establece respaldos mediante instantáneas semanales. Un respaldo semanal implica un objetivo de punto de recuperación de hasta siete días. Ante un incidente de cifrado malicioso o de pérdida de la base de datos, la restauración se mediría en días y con pérdida de una semana completa de transacciones comerciales, es decir, precisamente lo contrario de lo que el modelo exige cuando pide restaurar en minutos y no en semanas.

Tabla 1

Correspondencia entre los vértices del modelo, las capas del esquema de seguridad y los controles de la norma

Vértice	Capa del esquema de seguridad	Componentes del proyecto	Controles del Anexo A de ISO/IEC 27001:2022
Protección	Capas 1 a 6: perímetro, red, sistema operativo, servidor web y WAF, aplicación y datos	Cloudflare, UFW, fail2ban, CIS Benchmark, Nginx, ModSecurity 3.0, OWASP CRS 4.x, MFA, RBAC, TLS 1.3, AES-256 y tokenización	6.3, 8.5, 8.8, 8.20, 8.23, 8.24, 8.26 y 8.28
Detección	Control transversal de monitoreo	Wazuh SIEM, puntuación de anomalía del CRS, monitoreo de integridad de archivos, OWASP ZAP, Nmap y Lynis	5.7, 8.15 y 8.16
Respuesta	No cubierta por el esquema vigente	Pendiente de incorporar: plan conforme a NIST SP 800-61r3, procedimientos de aislamiento, respaldo diario verificado y matriz de escalamiento	5.24, 5.25, 5.26, 5.27, 5.28, 5.29, 5.30 y 8.13

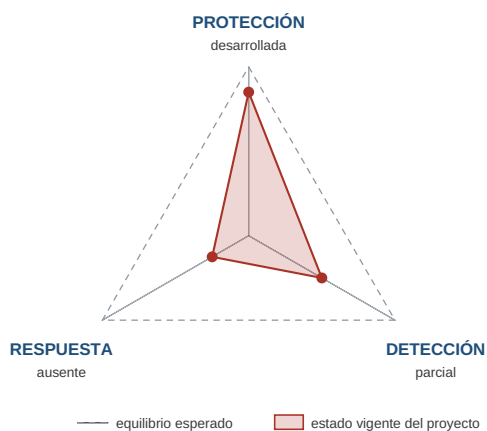
Nota. Los controles citados en el documento vigente pertenecen casi en su totalidad a la familia 8.2x, correspondiente a medidas técnicas de protección. La incorporación del vértice de respuesta obliga a sumar la familia 5.2x, relativa a la gestión de incidentes, y los controles 5.29 y 5.30 sobre continuidad del negocio.

3. Diagnóstico del Equilibrio Actual

El modelo condiciona la supervivencia del negocio al equilibrio de las tres aristas, de modo que la evaluación pertinente no consiste en verificar si cada vértice existe, sino en medir cuánto se aleja el triángulo del proyecto de una figura equilátera. La Figura 2 representa esa comparación.

Figura 2

Desequilibrio entre los tres vértices en el estado vigente del proyecto



Nota. La distancia de cada vértice respecto del centro representa la madurez del control correspondiente. El triángulo resultante es escaleno, lo que indica que la seguridad del sistema descansa de forma desproporcionada sobre la capacidad preventiva.

La lectura de la figura es directa: el proyecto es una propuesta de protección con instrumentación de detección incompleta y sin capacidad de respuesta formalizada. Esto no invalida el trabajo realizado, pero sí acota su alcance real. En términos de auditoría, un sistema con este perfil supera una revisión de controles técnicos y falla una revisión de gestión, porque la norma ISO/IEC 27001 no certifica herramientas sino procesos.

La Tabla 2 detalla cada brecha identificada, la acción correctiva propuesta y su costo incremental sobre el presupuesto original del proyecto.

Tabla 2*Brechas detectadas por vértice y acciones correctivas propuestas*

Vértice	Brecha detectada	Acción correctiva	Costo incremental
Protección	No se documenta la formación continua del personal, pese a que el modelo la exige en este vértice	Plan de concienciación semestral con material de la Fundación OWASP y registro de asistencia	Q0.00
Protección	La gestión de parches carece de un acuerdo de nivel de servicio verificable	Ventana máxima de 72 horas para vulnerabilidades críticas, verificada mediante auditoría con Lynis	Q0.00
Detección	Wazuh está desplegado pero no se define quién monitorea las alertas ni en qué horario	Turno de guardia documentado, casos de uso de alerta priorizados y procedimiento de triaje	Q0.00
Detección	Los registros de Cloudflare y de la aplicación Laravel no se integran al SIEM	Envío de ambas fuentes al agente de Wazuh para completar la correlación de las seis capas	Q0.00
Detección	No se declara una política de retención de registros	Retención de 90 días en línea y 12 meses en almacenamiento frío, conforme al control 8.15	Q0.00
Respuesta	No existe un plan de respuesta a incidentes entre los entregables del cronograma	Redacción del plan conforme a NIST SP 800-61r3, con procedimientos operativos por tipo de incidente	Q0.00
Respuesta	El respaldo semanal implica un objetivo de punto de recuperación de hasta siete días	Volcado diario cifrado de la base de datos hacia almacenamiento externo, bajo el esquema 3-2-1	Q20.00 mensuales
Respuesta	No se contempla la verificación de que los respaldos sean restaurables	Prueba mensual de restauración en entorno aislado, con acta de resultado	Q0.00
Respuesta	No se definen matriz de escalamiento ni plan de comunicación ante una brecha	Definición de roles, tiempos de escalamiento y procedimiento de notificación a los titulares de los datos	Q0.00

Nota. El único desembolso adicional corresponde al almacenamiento externo de respaldos, estimado en Q80.00 para los cuatro meses de duración del proyecto. Ese monto se absorbe dentro de la reserva de contingencia de Q97.20 ya prevista en el presupuesto original, por lo que la corrección del vértice de respuesta no incrementa el costo total del proyecto.

4. Integración con el Ciclo SKiP y Métricas de Verificación

El proyecto ya adopta el modelo SKiP como ciclo de defensa continua, de manera que el triángulo no introduce un marco competidor sino una lectura estructural del mismo ciclo. Las fases de asegurar y preparar alimentan el vértice de protección, la fase de detectar corresponde al vértice de detección, la fase de responder constituye el vértice de respuesta y la fase de mejorar opera de forma transversal sobre los tres, cerrando el circuito representado en la Figura 1.

La misma correspondencia se sostiene con las funciones del Marco de Ciberseguridad 2.0 del NIST, sobre el cual se construye la norma SP 800-61r3 citada en el proyecto: las funciones de proteger, detectar, y responder junto con recuperar, se alinean con los tres vértices, mientras que gobernar e identificar constituyen los requisitos previos que hacen posible el ciclo.

Ahora bien, un modelo de equilibrio solo resulta auditable si cada vértice se acompaña de una métrica verificable. La Tabla 3 propone el conjunto mínimo de indicadores que permitiría demostrar, ante una auditoría, que las tres aristas se sostienen y no solo se declaran.

Tabla 3

Métricas de verificación propuestas por vértice del modelo

Vértice	Métrica	Definición operativa	Meta propuesta
Protección	Cobertura de parcheo crítico	Porcentaje de vulnerabilidades críticas corregidas dentro de la ventana establecida	100 % en 72 horas
Protección	Personal capacitado	Porcentaje del equipo con capacitación en seguridad vigente	100 % semestral
Detección	Tiempo medio de detección	Intervalo entre la ocurrencia del evento y la generación de la alerta en Wazuh	Menor o igual a 30 minutos
Detección	Tasa de falsos positivos	Proporción de respuestas HTTP 403 emitidas sobre tráfico legítimo por el Core Rule Set	Menor al 2 %
Respuesta	Tiempo medio de contención	Intervalo entre la alerta confirmada y el aislamiento del componente comprometido	Menor o igual a 2 horas
Respuesta	Objetivo de tiempo de recuperación	Plazo máximo para restablecer el servicio tras una interrupción mayor	4 horas
Respuesta	Objetivo de punto de recuperación	Pérdida máxima de datos tolerable, medida desde el último respaldo verificado	24 horas

Nota. Las metas propuestas son coherentes con la capacidad del servidor virtual privado contratado, de 2 vCPU y 4 GB de memoria, y con el tamaño del equipo del proyecto. Un objetivo de recuperación más agresivo exigiría infraestructura redundante que el presupuesto vigente no contempla.

5. Ajustes Derivados para el Documento del Proyecto

La aplicación del modelo produce cinco modificaciones concretas sobre el documento vigente, todas ellas de alcance limitado y sin impacto en el costo total.

- Incorporar a la tabla de estándares aplicados los controles 5.24 a 5.28 del Anexo A, relativos a la planificación, evaluación, respuesta, aprendizaje y recopilación de evidencias en la gestión de incidentes, así como los controles 5.29 y 5.30 sobre continuidad del negocio y los controles 8.13, 8.15 y 8.16 sobre respaldos, registro de eventos y actividades de seguimiento.
- Sustituir el esquema de respaldos por instantáneas semanales por un esquema de volcado diario cifrado hacia almacenamiento externo, y declarar de manera explícita los objetivos de recuperación de 4 y 24 horas.
- Reformular el primer objetivo del modelo de negocio, acotando el compromiso de disponibilidad del 99.9 % a la resistencia frente a denegación de servicio, que es lo que la arquitectura efectivamente sostiene, o bien ajustar la cifra a un valor respaldado por la capacidad de recuperación declarada.
- Ampliar la fase 6 del cronograma para incluir un simulacro de incidente de mesa, que permita ensayar los procedimientos antes de la puesta en producción, sin modificar la duración total de 16 semanas.
- Agregar a los entregables de la fase 7 el plan de respuesta a incidentes y la matriz de escalamiento, junto con el manual de operación y la política de seguridad ya previstos.

Conclusión

El proyecto construyó una propuesta técnicamente sólida sobre un solo vértice del modelo. Completar los dos restantes no requiere rediseñar la arquitectura ni ampliar el presupuesto: exige documentar la operación de las herramientas ya seleccionadas y formalizar los procedimientos de recuperación. Ese cambio es, en última instancia, el que convierte la propuesta de un catálogo de controles técnicos en un sistema de gestión de la seguridad de la información, que es lo que la norma ISO/IEC 27001 evalúa.

Referencias

- Nelson, A., Rekhi, S., Souppaya, M., y Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST SP 800-61r3). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r3>
- Organización Internacional de Normalización. (2022). *ISO/IEC 27001:2022. Seguridad de la información, ciberseguridad y protección de la privacidad. Sistemas de gestión de la seguridad de la información. Requisitos.*
- Organización Internacional de Normalización. (2022). *ISO/IEC 27002:2022. Controles de seguridad de la información.*
- OWASP Foundation. (2026). *OWASP Core Rule Set*. <https://coreruleset.org/>
- PCI Security Standards Council. (2024). *Payment Card Industry Data Security Standard: Requirements and testing procedures* (v4.0.1).
- Rompich Yoc, M. R., Herrera Soto, J. R., y Beteta García, D. A. (2026). *Propuesta de solución de seguridad para una plataforma de comercio electrónico (E-Commerce SaaS): Implementación de un Web Application Firewall bajo la norma ISO/IEC 27001* [Proyecto de curso]. Universidad Mariano Gálvez de Guatemala.